

MÉMOIRE DE FIN D'ÉTUDES - ENSPY
AUDIT DE SÉCURITÉ APPLICATIVE FUSIONNÉ
Méthode MUSA - Cas GIDOCEP / SOLTEC

DOCUMENTS À SOLLICITER EN PHASE PRÉPARATOIRE

Mission MUSA-GIDOCEP-2026-SOLTEC

Référence mission	MUSA-GIDOCEP-2026-SOLTEC
Type de document	Documents à solliciter en phase préparatoire
Date d'établissement	
Version	V1.0 Finale (collecte documentaire réalisée en Phase 1)
Statut	
Commanditaire	Direction Générale SOLTEC
Chef de mission	TOMI OLAMA Gabrielle Solange, étudiante-auditrice, ENSPY
Classification	CONFIDENTIEL, Usage exclusif mission de fin d'études

Les documents suivants doivent être obtenus avant le démarrage des travaux de terrain. L'absence de tout document de priorité H constitue un constat PAS à noter dans l'Outil MUSA c'est-à-dire une insuffisance sur la réponse de l'audité.

Priorité H = à obtenir avant tout démarrage du terrain | Priorité M = à obtenir avant la clôture de la planification | Document absent = constat PAS à documenter

1. Documents transversaux (cadrage de la mission)

Réf.	Document requis	Utilité pour l'auditeur	Priorité	Obtenu ?
T01	Organigramme simplifié de SOLTEC et positionnement de l'équipe GIDOCEP	Identifier les responsabilités et construire une matrice RACI minimale	H	Non obtenu organigramme non fourni
T02	Lettre de mission / accord de l'encadreur professionnel SOLTEC	Formaliser le mandat de la mission académique et les droits d'accès	H	Obtenu, accord verbal de l'encadreur professionnel, confirmé en réunion de lancement
T03	Fiche technique et TDR de la mission (Outils 1 et 2) signés	Cadrer le mandat, le périmètre, la durée et les objectifs	H	Obtenu, TDR et Fiche technique signés
T04	Tout rapport ou audit antérieur portant sur GIDOCEP (le cas échéant)	Identifier des constats préexistants et leur suivi	M	Partiellement obtenu, synthèse partielle du rapport d'audit ST DIGITAL (2026) uniquement
T05	Liste des interlocuteurs SOLTEC disponibles et planning	Optimiser le calendrier des entretiens fusionnés	M	Obtenu, plein accès aux interlocuteurs prévus (Direction, responsable technique, utilisateurs)

2. Documents spécifiques à GIDOCEP (par domaine fusionné MUSA)

Cette liste remplace, pour un audit fusionné mono-applicatif, la longue liste de documents S01-S18 d'un audit SI multi-logiciel classique. Elle est resserrée à 19 pièces (13 initiales + 6 ajoutées lors de l'extension du référentiel de 15 à 21 assertions), chacune reliée à une ou plusieurs assertions fusionnées du référentiel MUSA, au lieu de 205 assertions dans un audit SI multi-logiciel classique.

Réf.	Document requis	Utilité pour l'auditeur	Domaine MUSA	Priorité	Statut réel de collecte
G01	Spécifications fonctionnelles et techniques de GIDOCEP	Comprendre le périmètre fonctionnel et l'architecture applicative	Transversal	H	Obtenu manuel de formation GIDOCEP (SOLTEC, 2020) fourni
G02	Schéma d'architecture technique (infrastructure, base de données, hébergement)	Orienter les tests techniques par domaine	C, D	H	NON OBTENU absence explicitement constatée en Phase 1
G03	Matrice des droits d'accès et liste des profils utilisateurs GIDOCEP (actifs + inactifs)	Détecter cumuls de droits, comptes dormants, accès non autorisés	A	H	NON OBTENU, absence explicitement constatée en Phase 1
G04	Politique de mots de passe et configuration d'authentification (MFA si applicable)	Évaluer le critère technique de l'assertion A1	A	H	NON OBTENU, aucune politique formelle fournie
G05	Extraits de configuration ou de code du mécanisme de journalisation applicative	Vérifier l'existence et l'intégrité des logs (assertion B1)	B	H	Partiellement obtenu constaté par observation directe du journal des opérations ; aucune configuration fournie en tant que document
G06	Configuration ou rapport IDS/IPS si existant, procédure de réponse aux alertes	Évaluer l'assertion B2 (détection d'intrusion)	B	M	NON OBTENU / non applicable ; aucun dispositif IDS/IPS identifié
G07	Politique de classification et de chiffrement des données ; rapport de scan TLS	Évaluer l'assertion C1 (chiffrement)	C	H	NON OBTENU, absence de politique confirmée ; le constat HTTP/non-HTTPS provient d'une observation de l'auditrice, non d'un document fourni
G08	Spécifications des règles de validation des entrées et des règles de diffusion des sorties	Évaluer les assertions C2 et C3	C	M	NON OBTENU
G09	Documentation des interfaces inter-applicatives de GIDOCEP (API, échanges de données)	Évaluer l'assertion C4 (sécurité des interfaces)	C	M	NON OBTENU, interface avec CADRE mentionnée mais non documentée
G10	Journal de sauvegarde des 3 à 12 derniers mois et rapport de test de restauration	Évaluer les assertions D1 et D2 (continuité)	D	H	NON OBTENU, sauvegardes confirmées uniquement par déclaration orale en entretien (non testées, non documentées)
G11	Preuve de désignation d'un propriétaire applicatif GIDOCEP (note, fiche de poste)	Évaluer l'assertion E1	E	H	NON OBTENU, désignation informelle du RSSI en entretien uniquement, sans fiche de poste
G12	Rapport de gestion des patches / politique de patching, guide de codage sécurisé si existant	Évaluer les assertions E2 et E3 (patches, injections SQL)	E	M	NON OBTENU
G13	Rapport de conformité aux benchmarks de durcissement (CIS ou équivalent) si existant	Évaluer l'assertion E4	E	M	NON OBTENU
G14	Configuration ou export du système de versionnement des documents comptables (historique des versions)	Évaluer l'assertion G1 (contrôle de version des documents)	C (G1)	M	NON OBTENU, non testé, hors capacité de vérification de la mission

G15	Politique de classification des documents comptables par niveau de sensibilité	Évaluer l'assertion G2 (classification des documents)	C (G2)	H	NON OBTENU, non testé, information non collectée
G16	Extrait du journal des consultations de documents sensibles (distinct du journal général des opérations)	Évaluer l'assertion G3 (journalisation des consultations)	B (G3)	M	NON OBTENU, seul le journal général des opérations a été observé
G17	Matrice des droits d'accès par type de document comptable	Évaluer l'assertion G4 (droits d'accès par document)	C (G4)	H	NON OBTENU, même constat que G03 (absence de matrice des droits)
G18	Politique et configuration d'archivage électronique légal des documents comptables	Évaluer l'assertion G5 (archivage légal)	D (G5)	H	NON OBTENU, non testé, information non collectée
G19	Procédure de destruction/effacement sécurisé des documents comptables en fin de cycle de vie	Évaluer l'assertion G6 (destruction sécurisée)	E (G6)	M	NON OBTENU, non testé, information non collectée

Méthode MUSA (Inspirée du chapitre 7 Cours d'Audit des Systèmes d'Informations | HN3-ENSPY | cours disponible sur le dépôt github : <https://github.com/Maletyon/INF3226/tree/chapitres>